

****Phase 1 Complete****

I made small foundation/security changes only. No advanced features were added.

Highest-risk issues addressed:

- Centralized admin API auth in

[lib/admin-auth.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/lib/admin-auth.ts).

- Applied admin auth guards to admin/operations APIs:

-

[app/api/admin/products/route.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/app/api/admin/products/route.ts)

-

[app/api/admin/inventory/route.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/app/api/admin/inventory/route.ts)

-

[app/api/admin/settings/route.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/app/api/admin/settings/route.ts)

-

[app/api/orders/route.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/app/api/orders/route.ts) for reads/status changes

-

[app/api/pick-tickets/route.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/app/api/pick-tickets/route.ts)

- Production-gated unsafe durable customer endpoints until real customer auth/session ownership exists:

-

[app/api/saved-carts/route.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/app/api/saved-carts/route.ts)

-

[app/api/customer-drawings/route.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/app/api/customer-drawings/route.ts)

- Added production `/admin` UI lock in

[middleware.ts](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/middleware.ts), because the app does not yet have server-readable Supabase Auth sessions for page protection.

- Added Vercel config/security headers in

[vercel.json](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/vercel.json).

- Added GitHub CI in

[.github/workflows/ci.yml](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/.github/workflows/ci.yml).

- Converted lint from deprecated interactive `next lint` to ESLint CLI via

[eslint.config.mjs](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/eslint.config.mjs) and

[package.json](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/package.json).

- Updated

[.env.example](/Users/brendan-macpro/Documents/Gateworks%20Shopping%20App/.env.example) with `ADMIN\_REQUIRE\_AUTH=true`.

****Checks Run****

- ESLint: passed.
- TypeScript: passed.
- Production build: passed.
- Sensitive key scan: service role is only referenced server-side/config examples; no `NEXT\_PUBLIC\_` service-role exposure found.

I used the bundled Node runtime because `npm` is not available on this shell PATH, but the underlying commands were the same lint/typecheck/build paths.

****Remaining Risks****

- Admin UI is intentionally disabled in production until real Supabase Auth UI plus SSR/session-cookie guards exist.
- Customer auth is still not production-grade; saved carts and drawing uploads are now blocked in production rather than left unsafe.
- Order creation is still public and uses client-submitted totals/prices; before launch, the server should recalculate from catalog data.
- Supabase `Database` types are still missing.
- Storage bucket privacy still needs a schema change: `customer-drawings` should become private with signed URL access.
- CI depends on GitHub secrets being configured.

****Preview Deployment Status****

Safe for a restricted preview deployment if Vercel has the Supabase env vars and `ADMIN\_REQUIRE\_AUTH=true`.

Not safe for production launch yet. Before launch: implement real admin/customer auth, signed private uploads, server-side order pricing, generated Supabase DB types, and a Supabase RLS/grants review against the live database.